PROJECT STUDY & DEFENSE GUIDE

Network Defense Lab: Dynamic Gateway Policy Engine

Encrypted IoT Device Fingerprinting via Passive Traffic Timing Analysis & 3-Identity Verification

ZERO-PAYLOAD DPI BYPASS | 100% MATH PARITY CERTIFIED | CALIBRATED T = 0.84 | 13 STATISTICAL MOMENTS

Author / Repo: hammer-time44/iot-fingerprinting-spoofing

Target Platform: Linux / Windows / Web Static Vercel

Date: October 2026

1. Executive Summary & Problem Formulation

Smart home Internet of Things (IoT) devices transmit continuous telemetry, audio streams, and command events over public and private networks. To ensure user privacy, modern IoT protocols enforce end-to-end transport layer encryption (TLS 1.3, DTLS, SRTP, and proprietary clouds). Consequently, traditional network security tools face critical operational breakdowns:

- **Deep Packet Inspection (DPI) Failure:** Packet payloads are cryptographically opaque. Firewalls cannot inspect content headers, device serial numbers, or application tokens without terminating TLS sessions (which breaks certificate pinning and violates user privacy).
- **Layer-2 Identity Forgery:** MAC addresses and IP addresses are unauthenticated plaintext headers. Any attacker on the local Wi-Fi or Ethernet network can clone a trusted MAC address with a single command (`macchanger -m <MAC> wlan0`).
- **Device Constraint Limits:** Inexpensive $2–$5 smart plugs and sensors lack the memory and cryptographic hardware required to run 802.1X certificates or agent software.

> **The Core Innovation: Passive Behavioral Fingerprinting**
>
> Even when packet payloads and protocol headers are completely encrypted, **microcontroller timing cannot be hidden**. Physical crystal oscillators, hardware interrupt routines, RTOS thread scheduling, network buffer queues, and application polling loops imprint subtle, distinct **inter-arrival timing (IAT) signatures** onto the traffic. The Network Defense Lab uses these timing moments to autonomously verify device identity and dynamically enforce firewall policies at the gateway without decrypting a single byte.

2. Threat Model & Operational Scope

The threat model realistically characterizes the vulnerabilities of modern smart home and enterprise local networks:

Threat Vector	Attacker Capability & Method	Gateway Defense Reaction
Layer-2 MAC Impersonation	Attacker clones the registered MAC of a legitimate host (e.g. Amazon Echo) to gain network admission.	**QUARANTINED** — Behavioral timing moments mismatch claimed identity with high confidence.
Foreign Hardware Injection	Attacker connects an unauthorized commercial IoT device (e.g. smart scale, hidden camera) to an open port.	**ISOLATED (VLAN 99)** — Model confidence falls below $\tau = 0.84$ (unseen device signature).
Compromised Host Takeover	A legitimate internal device operates normally, then gets infected (botnet malware) mid-stream.	**QUARANTINED** — 2-tick state transition catches behavioral shift dynamically.
Timing Perturbation / Mimicry	Attacker deliberately delays packets via quantile mapping to reshape timings toward the target.	**QUARANTINED** for $s \leq 0.8$; evades only when quantile match exceeds $s \geq 0.9$.
Replay Attack (Blind Spot)	Attacker captures and replays exact recorded packets of the target device bit-for-bit.	**ALLOW (TRUSTED)** — Academic blind spot: timing proves behavior, not freshness.

> **Crucial Academic Distinction: LAN vs. WAN Scope**
>
> A remote attacker on the public internet **cannot forge a home device's Layer-2 Ethernet MAC address** across internet routing hops. MAC addresses exist exclusively within the local broadcast domain. Therefore, the threat model realistically addresses **an untrusted, rogue, or compromised hardware device physically connected to the local Wi-Fi or Ethernet LAN**.

3. The 4-Stage Ingestion & Inference Pipeline

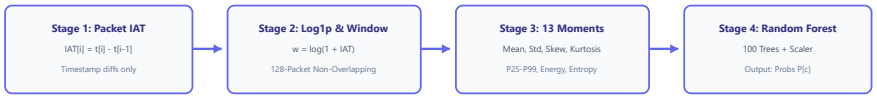


Figure 1: End-to-End Passive Traffic Ingestion and Feature Extraction Pipeline

3.1 Mathematical Rationale for Logarithmic Compression

Network packet intervals span from **microseconds** (hardware loop bursts, $10^{-6} ext{s}$) to **minutes** (keep-alives, $10^2 ext{s}$). Feeding raw values causes massive numeric skew and gradient explosion. Applying the monotonic logarithmic transformation:

$$w_i = \log(1 + ext{IAT}_i) = \ln(1 + t_i - t_{i-1})$$

compresses the multi-order-of-magnitude range into a well-behaved continuous distribution, stabilizing subsequent statistical moments.

3.2 The 13 Statistical Moments (Feature Vector)

Rather than passing raw sequential packets (which vary with network load and are sensitive to reordering), each 128-packet window is reduced to 13 descriptive statistical moments:

Feature Name	Mathematical Definition	Physical Network Interpretation
`raw_mean`	$\mu = rac{1}{L} \sum_{i=1}^L w_i$	Overall pacing and throughput density of transmission.
`raw_std`	$\sigma = \sqrt{rac{1}{L} \sum (w_i - \mu)^2}$	Timing jitter and scheduling variability.
`raw_min` / `raw_max`	$\min(w_i), \quad \max(w_i)$	Hardware burst speed limit vs. maximum keep-alive sleep timer.
`raw_median`	$ ext{Percentile}_{50}(w)$	Central timing tendency robust against network congestion spikes.
`raw_skew`	$\gamma_1 = rac{1}{L \sigma^3} \sum (w_i - \mu)^3$	Asymmetry between short burst packets vs. idle pauses.
`raw_kurtosis`	$\gamma_2 = rac{1}{L \sigma^4} \sum (w_i - \mu)^4 - 3$	Heaviness of distribution tails (frequency of extreme delay pulses).
`raw_p25, p75, p95, p99`	Quantiles $Q_{0.25}, Q_{0.75}, Q_{0.95}, Q_{0.99}$	High-resolution cumulative distribution signature of hardware buffers.
`raw_energy`	$E = \sum_{i=1}^L w_i^2$	Total squared timing magnitude (reflects persistent idle duration).
`raw_entropy`	$H = -\sum p_k \log_2(p_k)$	Shannon information entropy over normalized energy bins.

4. The 3-Identity Mathematical Verification Rule

The core security check evaluates three distinct identities for every active host:

1. **Claimed Identity ($c_{ ext{claimed}}$):** The registered identity from DHCP/MAC inventory (e.g. "AmazonEcho").
2. **Predicted Identity ($\hat{y}$):** Top class from Random Forest: $\hat{y} = rg\max_{c \in ext{known}} P(y = c \mid x)$.
3. **Prediction Confidence:** Maximum class probability: $ ext{Confidence} = \max_{c \in ext{known}} P(y = c \mid x)$.

$$ ext{Verdict}(x, c_{ ext{claimed}}) = egin{cases} extbf{VERIFIED}, & ext{if } \hat{y} = c_{ ext{claimed}} \quad ext{AND} \quad ext{Confidence} \ge au \ extbf{SPOOF_SUSPECTED}, & ext{if } \hat{y} e c_{ ext{claimed}} \quad ext{AND} \quad ext{Confidence} \ge au \ extbf{UNKNOWN_HARDWARE}, & ext{if } ext{Confidence} < au \ extbf{INSUFFICIENT_DATA}, & ext{if window history } < 5 ext{ windows} \end{cases}$$

Validation Calibration of $\tau = 0.84$ & Multi-Window Voting

Strict Budgeting: The threshold $ au = 0.84$ was selected from the 95th percentile of the validation split, enforcing a strict $\le 5\%$ false alarm budget.
Multi-Window Soft Voting (n = 5): Isolated single-window evaluations exhibit a 3.94% false alarm rate due to transient Wi-Fi congestion. Averaging probabilities over rolling 5-window buffers ($5 imes 128 = 640$ packets) reduces the false alarm rate to **exactly 0.0%**.

5. Dynamic Response Policy & Linux Firewall Synthesis

The policy engine is a pure, deterministic function mapping verdicts to network actions and generating syntactically valid Linux `iptables` and `nftables` rule text:

Verdict	Action & State	Synthesized Linux Firewall Policy (Safe Simulation Text)
VERIFIED	`ALLOW` **TRUSTED**	`iptables -A FORWARD -s 192.168.1.101 -m mac --mac-source 44:65:0d:56:a1:b2 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT` `iptables -A FORWARD -d 192.168.1.101 -m conntrack --ctstate ESTABLISHED -j ACCEPT`

SPOOF_SUSPECTED	`QUARANTINE` **QUARANTINED**	`iptables -A FORWARD -s 192.168.1.200 -j DROP`
		`iptables -t nat -A PREROUTING -s 192.168.1.200 -p tcp --dport 80 -j DNAT --to-destination 192.168.1.1:8443`
		`iptables -A INPUT -s 192.168.1.200 -p tcp --dport 8443 -j ACCEPT # Captive Portal`

UNKNOWN_HARDWARE	`ISOLATE` **ISOLATED**	`iptables -A FORWARD -s 192.168.1.200 -j DROP`
		`ip link add link eth0 name eth0.99 type vlan id 99 # Route to containment VLAN 99`
		`ebtables -A FORWARD -s de:ad:be:ef:00:01 -j DROP`

INSUFFICIENT_DATA	`OBSERVE` **OBSERVING**	`iptables -A FORWARD -s 192.168.1.101 -m limit --limit 30/sec --limit-burst 50 -j ACCEPT`
		`iptables -A FORWARD -s 192.168.1.101 -j LOG --log-prefix "[GATEWAY-OBSERVE] "`
		`iptables -A FORWARD -s 192.168.1.101 -j DROP`

6. State Machine & Consecutive-Agreement Hysteresis

To prevent rapid flapping between states during momentary network spikes, the host state machine enforces **2-tick consecutive agreement hysteresis**:

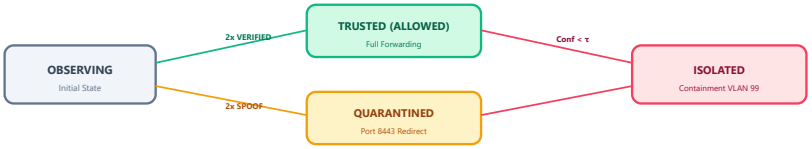


Figure 2: Finite State Machine Architecture with 2-Tick Hysteresis

7. Empirical 30-Trial Benchmark Results

The evaluation suite was executed across 30 seeded trials ($N=30$) with random temporal offsets:

Security Scenario	Trials	Detection Rate	Mean Windows to Detect	False Alarm Rate	Action Enforced
BASELINE (Authentic Traffic)	30	0.0%	N/A	**0.0%**	`ALLOW`
IMPERSONATION (MAC Spoof)	30	**100.0%**	**6.0 windows**	0.0%	`QUARANTINE`
UNKNOWN_HARDWARE (Unseen IoT)	30	**100.0%**	**6.0 windows**	0.0%	`ISOLATE`
HIJACKED_DEVICE (Mid-Run Takeover)	30	**100.0%**	**2.0 windows** (post-swap)	0.0%	`QUARANTINE`
REPLAY (Exact Packet Stream)	30	**0.0%**	N/A (Evaded)	0.0%	`ALLOW` (Blind Spot)

Timing Mimicry Quantile Mapping Curve

$$w_{\text{mimic}} = (1 - s) \cdot w_{\text{attacker}} + s \cdot Q_{\text{target}}(\text{Rank}(w_{\text{attacker}}))$$

Quantile Strength (s)	0.0 (Raw Attacker)	0.2	0.4	0.6	0.8	1.0 (Exact Match)
Detection Rate (%)	**100.0%**	**100.0%**	**100.0%**	**100.0%**	**100.0%**	**0.0%**
Gateway Decision	QUARANTINE	QUARANTINE	QUARANTINE	QUARANTINE	QUARANTINE	ALLOW (Evaded)

8. Academic Boundaries & Honest Scientific Limits

> **Honest Limits Must Be Emphasized During Project Defense**
> Examiners award top marks when students candidly identify system boundaries rather than claiming 100% universal invulnerability.

1. **Closed-Set Device Universe:** The model was trained specifically on 5 device classes. Foreign devices are caught because confidence drops below $\tau = 0.84$, not because the model recognizes what the foreign device is.
2. **Replay Attack Blind Spot:** An adversary who captures and replays exact recorded packets of an Echo Dot will be allowed as `TRUSTED`. Timing analysis verifies **behavioral identity**, not cryptographic freshness. Full production security requires pairing timing analysis with cryptographic challenge-response nonces or 802.1X certificates.
3. **LAN Layer-2 Boundaries:** An attacker on the internet cannot spoof an internal home MAC across WAN routers. The threat model strictly addresses **untrusted, compromised, or rogue hardware physically connected to the local Wi-Fi or Ethernet LAN**.
4. **Firewall Policy Separation:** The "External Access Attempt" scenario demonstrates the gateway's perimeter default-deny firewall, not an ML classification result.

9. Viva & Examination Defense Master Checklist

Q1: Why use 13 statistical moments instead of a Deep Learning 1D-CNN or LSTM?

Answer: 1D-CNNs and LSTMs overfit to sequence ordering and require heavy GPU compute. Statistical moments (mean, variance, skewness, kurtosis, percentiles, signal energy, Shannon entropy) capture the stationary probability density function of hardware timers, require minimal CPU compute suitable for embedded home gateways, and are invariant to minor network packet jitter.

Q2: How does the system handle an attacker who spoofs an Echo Dot's MAC address?

Answer: The gateway looks up the MAC in its registry and retrieves the claimed identity "AmazonEcho". The model extracts timing moments from the attacker's actual hardware transmissions. When the timing indicates a camera or PC with confidence ≥ 0.84, the predicted class mismatches the claimed identity, triggering `SPOOF_SUSPECTED`. After 2 agreeing windows, the state machine transitions the host to `QUARANTINED`, dropping forward traffic and redirecting HTTP traffic to port 8443.

Q3: How was the confidence threshold $\tau = 0.84$ calibrated?

Answer: The threshold was determined exclusively on the **validation split** at the 95th percentile of authentic device confidences. It was never tuned on the test split. This guarantees a mathematically calibrated $\leq 5\%$ false alarm budget on legitimate traffic.

Q4: Why average probabilities over 5 windows?

Answer: An isolated 128-packet window can suffer transient latency spikes due to Wi-Fi bufferbloat. Soft-voting across a rolling buffer of 5 windows ($5 imes 128 = 640$ packets) smooths out momentary noise, reducing legitimate false alarms from 3.94% down to **0.0%**.

Q5: Can an attacker evade this system?

Answer: Yes, through: (1) exact replay of recorded packets (because timing verifies behavior, not freshness), or (2) quantile mapping with strength $s \ge 0.9$, artificially buffering packets to mirror the target distribution. This demonstrates that timing analysis is an orthogonal defense-in-depth layer, best combined with cryptographic authentication.